Ce qu'il faut savoir sur l'analyse d'impact relative à la protection des données (AIPD)

18 octobre 2017

L'AIPD un outil qui permet de construire un traitement conforme au RGPD et respectueux de la vie privée, lorsqu'un **traitement de données personnelles** *est susceptible d'engendrer un risque élevé pour les droits et libertés des personnes concernées.*

Qu'est-ce qu'une analyse d'impact relative à la protection des données (AIPD) ?

L'AIPD est un outil important pour la responsabilisation des organismes : elle les aide non seulement à construire des traitements de données respectueux de la vie privée, mais aussi à démontrer leur conformité au Règlement général sur la protection des données (RGPD). Elle est obligatoire pour les traitements susceptibles d'engendrer des risques élevés.

L'AIPD se décompose en trois parties :

- **Une description détaillée** du traitement mis en œuvre, comprenant tant les aspects techniques qu'opérationnels
- **L'évaluation, de nature plus juridique, de la nécessité et de la proportionnalité concernant les principes et droits fondamentaux** (finalité, données et durées de conservation, information et droits des personnes, etc.) non négociables, qui sont fixés par la loi et doivent être respectés, quels que soient les risques ;
- **L'étude, de nature plus technique, des risques sur la sécurité des données** (confidentialité, intégrité et disponibilité) **ainsi que leurs impacts potentiels sur la vie privée**, qui permet de déterminer les mesures techniques et organisationnelles nécessaires pour protéger les données.

On note qu'analyse d'impact relative à la protection des données, AIPD (Data Protection Impact Assessment, terme retenu dans le RGPD) et PIA (Privacy Impact Assessment, terme plus commun utilisé dans d'autres régions du monde) sont synonymes.

Qu'est-ce qu'un risque sur la vie privée ?

Un « risque sur la vie privée » est un scénario décrivant :

- un événement redouté (atteinte à la confidentialité, la disponibilité ou l'intégrité des données, et ses impacts potentiels sur les droits et libertés des personnes) ;
- toutes les menaces qui permettraient qu'il survienne.

Il est estimé en termes de **gravité** et de **vraisemblance**. La gravité doit être évaluée pour les personnes concernées, et non pour l'organisme.

Par exemple, un salarié soudoyé par un concurrent pourrait lui envoyer le **fichier** des adresses email des clients par courrier électronique. Si cela se produisait, les clients pourraient ensuite être sollicités et avoir un sentiment d'atteinte à la vie privée, des ennuis personnels ou professionnels, etc. Du point de vue « informatique et libertés », ce risque pourrait être estimé comme peu grave (conséquences peu importantes) et très vraisemblable (dans la mesure où ce scénario s'est déjà produit) par l'entreprise.

Une analyse d'impact peut-elle porter sur un ou plusieurs traitements ?

Oui : Une AIPD peut concerner un seul traitement ou un ensemble de traitements similaires.

Par exemple :

- des collectivités qui mettent chacune en place un système de **vidéosurveillance** similaire pourraient effectuer une seule analyse qui porterait sur ce système bien que celui-ci soit ultérieurement mis en œuvre par des responsables de traitements distincts ;
- un opérateur ferroviaire (**responsable de traitement** unique) pourrait effectuer une seule analyse d'impact sur le dispositif de la surveillance vidéo déployé dans plusieurs gares.

En tant que bonne pratique, une AIPD peut également être menée par le fournisseur d'un produit (matériel, logiciel ou service), pour évaluer l'impact sur la protection des données de son produit. Les différents responsables de traitement qui utilisent ensuite ce produit doivent mener leurs propres AIPD mais, le cas échéant, ceux-ci peuvent être alimentés par l'AIPD du fournisseur.

Quand est-ce qu'une analyse d'impact n'est pas obligatoire ?

Une AIPD n'est pas nécessaire dans les cas suivants :

- quand le traitement figure sur la liste des exceptions adoptée par la CNIL après consultation du CEPD (Comité européen de protection des données) ;
- quand le traitement ne présente pas de risque élevé pour les droits et libertés des personnes concernées ;
- lorsque la nature, la portée, le contexte et les finalités du traitement envisagé sont très similaires à un traitement pour lequel une AIPD a déjà été menée ;
- quand le traitement répond à une obligation légale ou est nécessaire à l'exercice d'une mission de service public (article 6 du RGPD), sous réserve que les conditions suivantes soient remplies :

1. qu'il ait une **base légale** dans le droit de l'UE ou le droit de l'État membre ;
2. que ce droit règlemente cette opération de traitement ;
3. et qu'une AIPD ait déjà été menée lors de l'adoption de cette base légale.

Quand est-ce qu'une analyse d'impact est obligatoire ?

Une AIPD doit obligatoirement être menée quand le traitement est « susceptible d'engendrer un risque élevé pour les droits et libertés des personnes concernées ».

- Soit le traitement envisagé figure dans la liste des types d'opérations de traitement pour lesquelles la CNIL a estimé obligatoire de réaliser une analyse d'impact relative à la protection des données.
- Soit le traitement remplit au moins **deux des neuf critères** issus des lignes directrices du **G29** :

- évaluation/*scoring* (y compris le profilage) ;
- décision automatique avec effet légal ou similaire ;
- surveillance systématique ;
- collecte de données sensibles ou données à caractère hautement personnel ;
- collecte de données personnelles à large échelle ;
- croisement de données ;
- personnes vulnérables (patients, personnes âgées, enfants, *etc.*) ;
- usage innovant (utilisation d'une nouvelle technologie) ;
- exclusion du bénéfice d'un droit/contrat.

Exemple : une entreprise met en place un traitement publicitaire visant à collecter les données de **géolocalisation** de plusieurs millions d'individus pour créer des profils publicitaires et leur afficher de la **publicité ciblée** en fonction de leurs déplacements ; ce traitement remplit le critère de la collecte à grande échelle et celui de la collecte de données sensibles (données de localisation), donc la réalisation d'une AIPD sera nécessaire.

À quel moment faut-il mener une analyse d'impact ?

L'AIPD doit être menée avant la mise en œuvre du traitement. Il doit être démarré le plus en amont possible et sera mise à jour tout au long du cycle de vie du traitement.

Il est également nécessaire de revoir une AIPD de manière régulière pour s'assurer que le niveau de risque reste acceptable tout au long de la vie du traitement, dans la mesure où l'environnement, technique notamment, sera amené à évoluer, ce qui nécessitera d'adapter les mesures mises en œuvre.

Faut-il mener une analyse d'impact pour les traitements déjà mis en œuvre au 25 mai 2018 ?

Une étude d'impact ne sera pas exigée pour :

- les traitements qui ont fait l'objet d'une formalité préalable auprès de la CNIL avant le 25 mai 2018, ou qui étaient dispensés de formalité.
- les traitements qui ont été consignés au registre d'un correspondant « informatique et libertés ».

Cette dispense d'obligation de réaliser une AIPD, pour les traitements existants et régulièrement mis en œuvre, sera limitée à une période de 3 ans : à l'issue de ce délai, les **responsables de traitement** devront avoir effectué une telle étude si le traitement est susceptible d'engendrer un risque élevé pour les droits et libertés des personnes.

En revanche, l'étude d'impact devra être réalisée, sans attendre l'issue de ce délai de trois ans, dans tous les autres cas, dès lors que le traitement présente un risque élevé :

- pour tout nouveau traitement mis en œuvre après le 25 mai 2018 ;
- pour les traitements antérieurs n'ayant pas fait l'objet de **formalités préalables** auprès de la CNIL ;
- pour les traitements, antérieurs au 25 mai et qui ont été dispensés d'étude d'impact en raison de l'accomplissement d'une formalité préalable auprès de la CNIL, mais qui font l'objet d'une modification significative.

La réalisation d'une AIPD constitue, dans tous les cas, une bonne pratique facilitant la démarche de mise en conformité avec les conditions de fond prévues par le RGPD.

Qui intervient dans la réalisation d'une analyse d'impact ?

Le **responsable de traitement** est tenu par l'obligation de s'assurer de la conformité de son traitement au RGPD.

S'il a désigné un **délégué à la protection des données**, il lui demande conseil et le charge de vérifier l'exécution de l'AIPD.

Si un **sous-traitant** intervient dans le traitement, il doit fournir son aide et les informations nécessaires à la réalisation de l'AIPD.

Le responsable de traitement devrait également demander l'avis **des personnes concernées** (par le biais d'une enquête, d'un sondage, d'une question formelle aux représentants du personnel), ou le justifier sinon.

Idéalement, les métiers (maîtrise d'ouvrage), les équipes chargées de la mise en œuvre (maîtrise d'œuvre), et la personne chargée de la sécurité des systèmes d'information devraient également participer au processus de réalisation de l'AIPD et à sa validation.

Comment fait-on une analyse d'impact, existe-t-il une méthode pour faire une analyse d'impact ?

Un AIPD contient au minimum :

- une **description** systématique des **opérations de traitement** envisagées et les **finalités** du traitement, y compris, le cas échéant, l'intérêt légitime poursuivi par le responsable du traitement ;

- une **évaluation de la nécessité** et de la **proportionnalité** des opérations de traitement au regard des finalités ;
- une **évaluation des risques** sur les droits et libertés des personnes concernées ; et
- les **mesures envisagées** pour faire face aux risques, y compris les garanties, mesures et mécanismes de sécurité visant à assurer la protection des données à caractère personnel et à apporter la preuve du respect du règlement.

Pour ce faire, **plusieurs méthodes sont utilisables**. Le responsable de traitement est libre de choisir sa méthode. Mais quelle que soit la méthode, celle-ci devrait respecter les critères définis dans l'annexe 2 des lignes directrices du G29.

Les guides AIPD de la CNIL décrivent la méthode suivante :

1. **délimiter et décrire le contexte** du (des) traitement(s) considéré(s) ;
2. **analyser les mesures** garantissant le respect des principes fondamentaux : la proportionnalité et la nécessité du traitement, et la protection des droits des personnes concernées ;
3. **apprécier les risques** sur la vie privée liés à la sécurité des données et vérifier qu'ils sont convenablement traités ;
4. **formaliser la validation** du PIA au regard des éléments précédents ou bien décider de réviser les étapes précédentes.

Faut-il publier l'analyse d'impact ?

Il n'y a aucune obligation de publication. Toutefois, l'AIPD peut aboutir à la production d'un rapport ou d'un résumé, pouvant être partagé, publié, communiqué. Cette bonne pratique contribue à améliorer la confiance entre les parties prenantes.

Quand faut-il transmettre son analyse d'impact à la CNIL ?

Si votre traitement relève du RGPD, votre AIPD doit être transmise à la CNIL dans les cas suivants :

- s'il apparait que le niveau de risque résiduel reste élevé (cas où la CNIL doit être consultée) ;
- quand la législation nationale d'un État membre l'exige ;

Si votre traitement relève de la directive « Police-Justice », votre AIPD doit être transmise à la CNIL dans les cas suivants :

- elle présente des risques résiduels élevés ;
- en raison de l'utilisation de nouveaux mécanismes, technologies ou procédures, le traitement présente des risques initiaux élevés.

Vous avez effectué une analyse d'impact mais vous n'êtes pas dans l'un des cas ci-dessus , vous n'avez pas à consulter la CNIL.

Comment envoyer son analyse d'impact (AIPD) à la CNIL ?

Si vous êtes dans un cas justifiant l'envoi de votre analyse d'impact, vous pouvez l'envoyer par internet.

Envoyer votre AIPD

Quel est le montant des sanctions prévues par le règlement en cas de manquements aux dispositions relatives aux analyses d'impact ?

Le montant des amendes peut s'élever jusqu'à 10 000 000 euros ou, dans le cas d'une entreprise, jusqu'à 2 % du chiffre d'affaires annuel mondial total de l'exercice précédent, le montant le plus élevé étant retenu (art. 83(4)(a)).

Infographie - Dois-je faire une AIPD ?

Accessibilité : cliquer pour accéder au texte de l'infographie

Pour approfondir

- Outil PIA : téléchargez et installez le logiciel de la CNIL (avec vidéo tutorielle)

Délibérations

- Délibération n° 2018-326 du 11 octobre 2018 portant adoption de lignes directrices sur les analyses d'impact relatives à la protection des données (AIPD) prévues par le règlement général sur la protection des données (RGPD)
- Délibération n° 2018-327 du 11 octobre 2018 portant adoption de la liste des types d'opérations de traitement pour lesquelles une analyse d'impact relative à la protection des données est requise
- Délibération n° 2019-118 du 12 septembre 2019 portant adoption de la liste des types d'opérations de traitement pour lesquelles une analyse d'impact relative à la protection des données n'est pas requise

Sommaire
Consulter la liste des traitements pour lesquels une AIPD est requise ou non >